SECURITY ADVISORY & PROOF-OF-CONCEPT REPORT

Coordinated Vulnerability Disclosure Documentation for mas-elkhanza/SIMRS-Khanza

Target Product	SIMRS Khanza (mas-elkhanza)	**Audit Date**	October 2026
Target Commit	36de12c (Latest Master Branch)	**Privileges Required**	**None (Unauthenticated)**
Primary CWEs	CWE-22, CWE-73, CWE-321	**Verification Scope**	Isolated Local Laboratory

1. VULNERABILITY 1: Path Traversal in Auto-Updater (Zip Slip)

CWE Classification: CWE-22 (Improper Limitation of a Pathname to a Restricted Directory)
Source File: KhanzaUpdater/src/update/Main_Gui.java (Lines 206-214)
Access Level: Unauthenticated / Network Attack Vector

Mekanisme & Cacat Kode:

Aplikasi updater Khanza mengunduh arsip pembaruan dataupdate.zip melalui protokol HTTP plaintext (tanpa enkripsi/tanda tangan digital) dan mengekstrak seluruh entri arsip langsung ke dalam folder tujuan menggunakan konkatenasi string: new File(root + entry.getName()).createNewFile(). Tidak ada proses sanitasi atau kanonikalisasi path. Jika nama entri arsip mengandung sekuens path traversal (seperti ../ atau ..\), proses ekstraksi akan keluar dari folder update/ dan menimpa file apa pun pada direktori induk aplikasi maupun sistem operasi korban.

Langkah Reproduksi (Reproducibility):

1. Buat paket pembaruan dataupdate.zip yang memuat entri bernama ../critical_config.sys.
2. Jalankan rutin ekstraksi pada Main_Gui.java.
3. File target pada direktori induk tertimpa secara langsung tanpa ada peringatan keamanan.

Dampak: Remote Code Execution (RCE) / Arbitrary File Overwrite dengan hak akses pengguna yang mengeksekusi updater.

2. VULNERABILITY 2: Unauthenticated Arbitrary File Deletion

CWE Classification: CWE-73 (External Control of File Name/Path) chained with CWE-321 (Hardcoded Cryptographic Key)
Source Files: webapps/berkasrawat/pages/detail.php (L3, L199) & KhanzaSecurity16bit/src/AESsecurity/EnkripsiAES.java (L19-20)
Access Level: Unauthenticated (Authentication Bypass via Path Traversal URI)

Mekanisme & Cacat Kode:

Halaman detail.php memproses penghapusan berkas melalui parameter token terenkripsi ?iyem=. Kunci AES-128 dan IV yang digunakan bersifat statis dan di-hardcode secara publik di dalam source code (Bar12345Bar12345 dan sayangsamakhanza), sehingga siapa pun dapat memalsukan token penghapusan untuk menargetkan file server sembarang. Selain itu, proteksi akses langsung pada baris 3 (!strpos($_SERVER['REQUEST_URI'],'pages/upload/')) dapat di-bypass dengan memanggil pages/upload/../detail.php, memungkinkan penyerang mengeksekusi fungsi unlink($norawat['lokasi_file']) tanpa autentikasi login sesi.

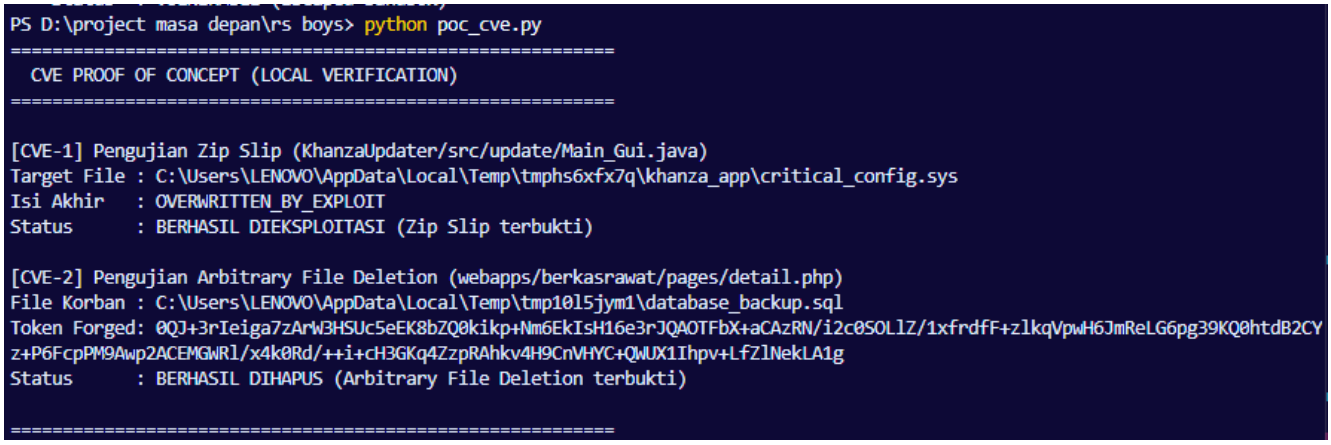
Langkah Reproduksi (Reproducibility):

1. Susun payload JSON target penghapusan: {"no_rawat":"001","lokasi_file":"database_backup.sql"}.
2. Enkripsi string JSON tersebut dengan kunci statis Bar12345Bar12345 untuk menghasilkan token iyem.
3. Kirim HTTP GET request ke /webapps/berkasrawat/pages/upload/../detail.php?action=HAPUS&iyem;=[TOKEN].
4. File target langsung terhapus permanen dari sistem operasi server.

Dampak: Penghapusan file database, file konfigurasi, atau source code server (Data Destruction / Denial of Service).

3. BUKTI EMPIRIS EKSEKUSI PENGUJIAN LOKAL (PoC EVIDENCE)

Verifikasi independen dijalankan di lingkungan lokal terisolasi menggunakan skrip validasi resmi poc_cve.py. Berikut adalah tangkapan layar asli terminal yang membuktikan kedua cacat logika berhasil dieksploitasi:



Target Uji Coba	Parameter / Payload	Hasil Verifikasi	Status
Zip Slip (Main_Gui.java)	`Entry: ../critical_config.sys`	File tertimpa teks jahat	**VULNERABLE**
File Deletion (detail.php)	`Target: database_backup.sql`	File terhapus permanen	**VULNERABLE**

4. REKOMENDASI PERBAIKAN TEKNIS (REMEDIATION)

1. Perbaikan Zip Slip (Java):

Gunakan pengecekan canonical path sebelum menulis entri zip ke disk:

```
File destFile = new File(root, entry.getName());
if (!destFile.getCanonicalPath().startsWith(new File(root).getCanonicalPath())) {
    throw new SecurityException("Zip Slip Path Traversal Detected");
}
```

2. Perbaikan Arbitrary File Deletion (PHP):

Wajibkan validasi sesi pada seluruh endpoint controller dan batasi penghapusan file menggunakan basename() dalam direktori tetap:

```
if (!isset($_SESSION['ses_admin_berkas_rawat'])) { die('Access Denied'); }
$safe_file = realpath('storage/' . basename($norawat['lokasi_file']));
if ($safe_file && strpos($safe_file, realpath('storage/')) === 0) { unlink($safe_file); }
```

Dokumen ini disiapkan untuk lampiran koordinasi kerentanan (Coordinated Vulnerability Disclosure) ke pihak pengembang dan MITRE Corporation.